SECURITY ENGINEERING RESEARCH POSTER

Static Security Analysis of AWS IAM Policies for AI Workload Identities

Detecting Excessive Privilege and Identity-Pivot Risks Before Deployment

github.com/poojakira/aws-agent-identity-guard - public, default branch main.

EVIDENCE POSTURE

Verified, scoped, reproducible

Claims are constrained to the repository evidence snapshot and stated limitations.

247	244	3	25
Tests collected	Tests passed	Tests skipped (credential-dependent)	Deterministic static rule IDs

SYSTEM VIEW

Architecture and Threat-Control Flow

Trust Boundary

Input surface
Data, models, requests, policies, or artifacts entering the tested path.

Control surface
Repository-specific validation, analysis, and fail-closed checks.

Evidence surface
Findings, metrics, tests, logs, or reproducible artifacts.

This diagram describes the tested repository path, not a universal deployment guarantee.

01 **Parse one IAM policy document without executing cloud actions.** →

02 **Classify statements and trust-policy structure.** ↓

03 **Apply deterministic rule checks for privilege escalation, excessive privilege, trust weaknesses, audit tampering, and missing boundaries.** →

04 **Emit findings with stable rule IDs and severity.** ↓

05 **Return CI-friendly exit codes and optional SARIF.**

Research Contribution

A deterministic, non-executing IAM linter specialized for AI-agent roles with 25 rule IDs spanning identity policies, trust policies, and permission-boundary risks, emitting text, JSON, and SARIF for pre-deployment review and CI gating.

Verified Evidence

EV-01 247 collected: 244 passed, 3 skipped, 0 failures/errors.

EV-02 25 deterministic rule IDs remain implemented and test-covered.

EV-03 Separately anchored earlier synthetic performance gate over 500 policies (not a measured result in the current test count): 0.8397 ms p95 and 2,573 policies/sec, both passing configured gates.

EV-04 Ruff/format and security-audit jobs complete successfully.

Method and Control Path

01 **Parse one IAM policy document without executing cloud actions.**

02 **Classify statements and trust-policy structure.**

03 **Apply deterministic rule checks for privilege escalation, excessive privilege, trust weaknesses, audit tampering, and missing boundaries.**

04 **Emit findings with stable rule IDs and severity.**

05 **Return CI-friendly exit codes and optional SARIF.**

Limitations and Residual Risk

- Performance values are CI microbenchmarks on synthetic policies, not production SLOs.
- The tool is a static analyzer, not a runtime authorization proxy.
- It does not prove account-wide effective permissions or every cross-resource escalation path.
- The 3 skipped tests require live AWS credentials; users must supply their own credentials through the standard AWS provider chain.

Reproducibility

```
Expected test evidence: 244 passed, 3 skipped (Oct 13
2026 CI run 38497940763). Measured code snapshot:
718582f5fd8419b0b8c2ca21361f7b0c715cb54b;
229605c9c53068f4c0d7116d67554d19afe30183 Evidence CI run:
38497940763; 37170669504
```

Evidence Provenance

Claim discipline
Metrics come from the repository's verified metrics and research brief.

Scope discipline
Benchmarks are reported only at their documented fixture, dataset, or test scope.

Reproduction
PDF and PNG are generated locally from committed evidence without paid services.

Evidence-backed security engineering

README, verified metrics, tests, CI, and committed artifacts remain authoritative. Poster layout emphasizes architecture, controls, evidence, limitations, and reproduction rather than unsupported efficacy claims.

36 x 48 in
PDF + PNG parity